

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I P.Gowtham Reddy (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: P.Gowtham Reddy

Annexure A

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

A. Explain why storing plain text passwords is insecure.

B. Suggest a secure method for storing passwords and justify your choice.

ANSWER:

Scenario

A company called ShopEase has developed a web application for online shopping. Thousands of users create accounts using their email addresses and passwords. Initially, the developers stored all user passwords in plaintext in the database because it was simple to implement.

One day, a cybercriminal exploited a security vulnerability and gained access to the database. Since the passwords were stored as plain text, the attacker could immediately read every user's password. Many customers had reused the same password for their email, banking, and social media accounts. As a result, the attacker was able to log into several other accounts, causing financial losses and identity theft. The company lost customer trust, received legal complaints, and suffered damage to its reputation.

To prevent such incidents in the future, the company decided to redesign its password storage system using secure password hashing techniques.

A. Why is storing plaintext passwords insecure?

Storing passwords in plaintext means the actual password entered by the user is saved directly in the database without any protection. This is highly insecure because:

1. If hackers gain access to the database, they can immediately view all passwords.
2. Attackers can use the stolen passwords to log into users' accounts without any extra effort.

3. Many users reuse the same password on multiple websites, allowing attackers to access email, banking, and social media accounts.
4. Employees or database administrators with database access can also view users' passwords, creating an insider security risk.
5. Plaintext storage violates standard cybersecurity practices and many security regulations.
6. The organization may lose customer trust, suffer financial losses, and face legal penalties after a data breach.

In the ShopEase scenario, storing plaintext passwords directly led to unauthorized access to thousands of customer accounts and serious financial and reputational damage.

B. Suggest a secure method for storing passwords and justify your choice

A secure solution is to store passwords using hashed and salted passwords with a strong password hashing algorithm such as bcrypt, Argon2, or PBKDF2.

Working of the secure method

1. The user creates a password during registration.
2. The system generates a unique random salt for that user.
3. The password and salt are combined.
4. The combined value is processed using a secure hashing algorithm such as bcrypt or Argon2.
5. Only the resulting hash and the salt are stored in the database.
6. During login, the entered password is hashed again with the stored salt and compared with the stored hash. If both values match, the user is authenticated.

Justification

- Hashing converts the password into an unreadable value that cannot be easily reversed.
- A unique salt ensures that even identical passwords produce different hashes.
- Algorithms such as bcrypt and Argon2 are intentionally slow, making brute-force attacks difficult.

- Rainbow table attacks become ineffective because every password has a different salt.
- Even if the database is stolen, attackers cannot directly obtain the original passwords.
- This approach follows industry best practices and greatly improves user security.

Conclusion

In the ShopEase case, the major mistake was storing passwords in plaintext. If the company had stored passwords as salted hashes using bcrypt or Argon2, the stolen database would not have revealed users' actual passwords. Therefore, every modern web application should store passwords using secure hashing and salting techniques to protect users from database breaches and maintain customer trust.

2. Digital Signature for Document Authentication

A company wants to ensure that official documents sent electronically are authentic and unaltered.

A. Explain how digital signatures can be used in this scenario.

B. Justify how this method ensures both integrity and non-repudiation.

ANSWER:

Scenario

A company named **ABC Technologies** regularly sends important documents such as employee appointment letters, salary revision letters, legal agreements, and financial reports to clients and employees through email. Since these documents contain confidential information, the company must ensure that:

- The documents are **authentic** (sent by the authorized person).
- The documents are **not modified** during transmission.
- The sender **cannot deny** sending the document later.

To achieve this, the company uses **Digital Signatures**.

A. Explain how Digital Signatures can be used in this scenario

A **Digital Signature** is a cryptographic technique that verifies the authenticity and integrity of electronic documents using **public key cryptography**.

Working Process

Step 1: Document Creation

The company prepares an official document (e.g., an appointment letter in PDF format).



Step 2: Generate Hash

A hash function (such as SHA-256) creates a unique fixed-size hash value (digital fingerprint) of the document.



Step 3: Sign the Hash

The sender encrypts the hash using their **private key**.
This encrypted hash becomes the **Digital Signature**.



Step 4: Send Document

The sender sends:

- Original Document
- Digital Signature



Step 5: Verification

The receiver:

- Uses the sender's **public key** to decrypt the digital signature.
- Generates a new hash of the received document.
- Compares both hash values.



Step 6: Authentication

- If both hashes are identical → Document is authentic and unchanged.
- If hashes differ → Document has been altered or the signature is invalid.

Flow Diagram

Sender Side

Document

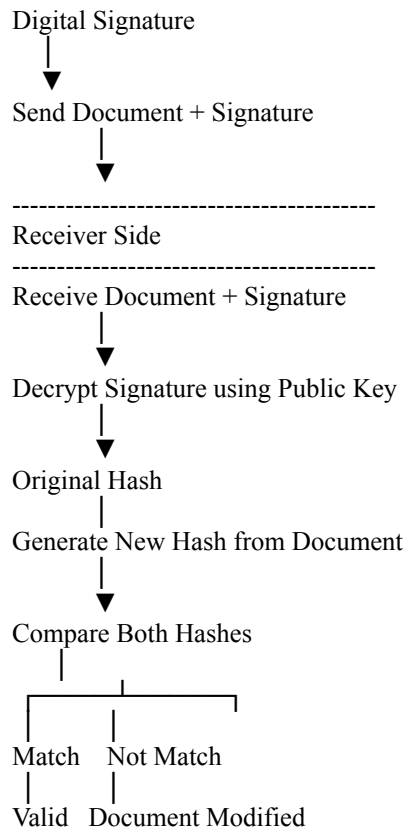


Generate Hash (SHA-256)



Encrypt Hash using Private Key





Example

The HR Manager of ABC Technologies sends an appointment letter to a new employee.

- The appointment letter is digitally signed using the HR Manager's private key.
- The employee receives the signed document.
- Using the HR Manager's public key, the employee verifies the signature.
- Since both hash values match, the employee confirms that:
 - The letter is genuine.
 - No one has changed its contents.
 - It was actually sent by the HR Manager.

B. Justify how this method ensures both Integrity and Non-Repudiation

1. Integrity

Definition:

Integrity means that the document remains unchanged during transmission.

How it is achieved

- The sender creates a hash of the document.
- The receiver also creates a hash after receiving it.
- Both hashes are compared.

If someone changes even **one character**, the hash value changes completely.

Example

Original document:

Salary = ₹50,000

Tampered document:

Salary = ₹90,000

The generated hash values become different.

Result:

Original Hash $\neq$ Received Hash

The receiver immediately knows the document has been modified.

Hence,

Digital Signature guarantees data integrity.

2. Non-Repudiation

Definition:

Non-repudiation means the sender cannot deny sending the document.

How it is achieved

- Only the sender possesses the private key.
- The digital signature is created using this private key.
- Anyone can verify it using the corresponding public key.

Therefore, if the signature is valid, it proves that the sender actually signed the document.

Example

Suppose the HR Manager later claims,

"I never sent this appointment letter."

The company verifies the digital signature.

Since the signature matches the HR Manager's public key, it proves that the document was signed using the HR Manager's private key.

Hence, the HR Manager **cannot deny** sending it.

Advantages of Digital Signatures

- Verifies the identity of the sender.
- Detects unauthorized document modifications.
- Provides data integrity.
- Ensures non-repudiation.
- Prevents forgery.
- Improves trust in electronic communication.
- Saves time and paperwork.

- Legally accepted in many countries.
-

Applications

- E-Governance documents
 - Banking transactions
 - Income Tax filing
 - Online contracts
 - Company agreements
 - Software distribution
 - Legal documents
 - Digital certificates
 - Business reports
 - Employee appointment letters
-

Conclusion

Digital signatures provide a secure and reliable method for authenticating electronic documents. By combining **hash functions** with **public key cryptography**, they ensure that documents are authentic, remain unaltered during transmission (**integrity**), and that the sender cannot deny signing them (**non-repudiation**). Hence, digital signatures are widely used in modern organizations for secure electronic communication.

3. Preventing Replay Attacks in Online Transactions

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

A. Explain how replay attacks occur.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

ANSWER:

Scenario

An online payment company named **PaySecure** allows customers to transfer money using a mobile application. A customer initiates a payment of **₹5,000** to a merchant. An attacker intercepts the payment request while it is being transmitted over the network. Later, the attacker resends the same captured transaction multiple times, causing the customer to be charged repeatedly. This is known as a **Replay Attack**.

A. Explain how Replay Attacks occur

A **Replay Attack** is a type of cyberattack in which an attacker captures a valid communication between two parties and retransmits it later to perform unauthorized actions.

Working Process

Step 1: Customer Initiates Payment

The customer sends a payment request of ₹5,000 to the payment server.

↓

Step 2: Attacker Captures the Transaction

The attacker intercepts and stores the payment request while it is transmitted over the network.

↓

Step 3: Original Transaction is Processed

The payment server successfully processes the customer's payment.

↓

Step 4: Attacker Replays the Message

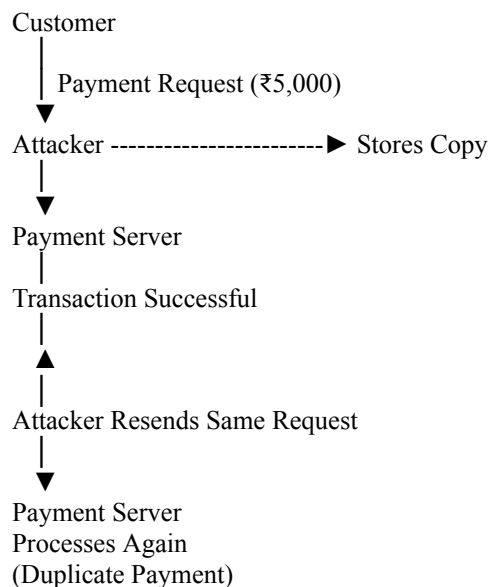
After some time, the attacker resends the same captured payment request to the server.

↓

Step 5: Duplicate Transaction

If the server cannot identify that the message is old, it processes the transaction again, resulting in multiple unauthorized payments.

Replay Attack Diagram



Example

A customer purchases a laptop worth **₹50,000** using an online payment application. The attacker captures the payment request and later sends the same request again. Without replay protection:

- First Payment → ₹50,000 ✓

- Replayed Payment → ₹50,000 ✓
- Total Deducted = ₹1,00,000

Thus, the customer suffers financial loss.

B. Suggest a Cryptographic Technique to Prevent Replay Attacks and Justify Your Answer

Technique: Nonce (Number Used Once) with Digital Signature or Message Authentication Code (MAC)

A **Nonce** is a randomly generated number that is used only once for each transaction.

Working Process

Step 1

The payment server generates a unique **Nonce** for every transaction.

↓

Step 2

The customer includes:

- Payment details
- Nonce
- Timestamp (optional)

The entire message is protected using a **Digital Signature** or **MAC**.

↓

Step 3

The payment server verifies:

- Signature/MAC
- Nonce
- Timestamp

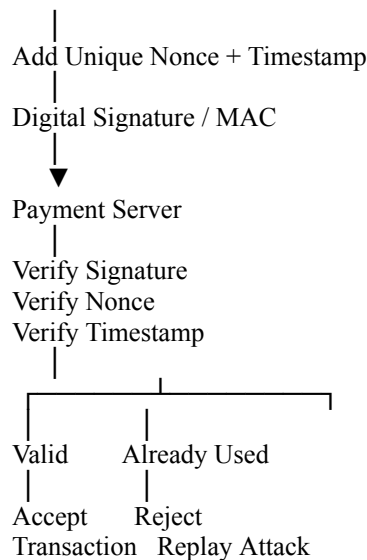
↓

Step 4

If the nonce has already been used, the server immediately rejects the transaction.

Flow Diagram

Customer
|
Generate Payment Request



Justification

1. Prevents Duplicate Transactions

Every payment contains a unique nonce. Once used, it cannot be reused. Any repeated transaction is automatically rejected.

2. Ensures Message Integrity

The digital signature or MAC protects the message from unauthorized modification. Any change in the transaction details causes verification to fail.

3. Provides Authentication

Only a legitimate user with the correct cryptographic key can generate a valid signature or MAC, ensuring the request is genuine.

4. Protects Against Replay Attacks

Even if an attacker captures the payment request, replaying it later will fail because the nonce has already been used or the timestamp has expired.

Advantages

- Prevents replay attacks.
 - Ensures secure online transactions.
 - Protects customer accounts from duplicate payments.
 - Maintains message integrity.
 - Authenticates the sender.
 - Reduces the risk of financial fraud.
 - Widely used in banking, UPI, credit card, and e-commerce systems.
-

Applications

- Online banking
 - UPI payments
 - Credit and debit card transactions
 - Mobile payment applications
 - E-commerce websites
 - Digital wallets
 - Internet banking
 - Secure API communication
-

Conclusion

Replay attacks occur when an attacker captures and retransmits a valid transaction to perform unauthorized actions. Using a **unique nonce** together with a **Digital Signature** or **Message Authentication Code (MAC)** ensures that each transaction is accepted only once. This provides **authentication**, **integrity**, and strong protection against replay attacks, making online payment systems secure and reliable.

4. Secure Communication over Public Wi-Fi

A user accesses sensitive information using a public Wi-Fi network without encryption.

A. Identify the risks involved in this scenario.

B. Recommend a secure communication method and justify how it protects user data.

ANSWER:

Scenario

A user visits a coffee shop and connects to the **free public Wi-Fi** to access online banking and check personal emails. The Wi-Fi network does **not use encryption**, allowing anyone on the same network to intercept the transmitted data. A cybercriminal connected to the same Wi-Fi captures the user's login credentials and sensitive information.

A. Identify the Risks Involved in this Scenario

Using an **unencrypted public Wi-Fi** network exposes users to several security threats.

1. Data Interception (Eavesdropping)

An attacker can capture data packets transmitted over the network, including usernames, passwords, banking details, and personal information.

2. Man-in-the-Middle (MITM) Attack

The attacker secretly intercepts and may alter communication between the user and the website without either party noticing.

3. Password Theft

If login credentials are sent without encryption, attackers can steal usernames and passwords.

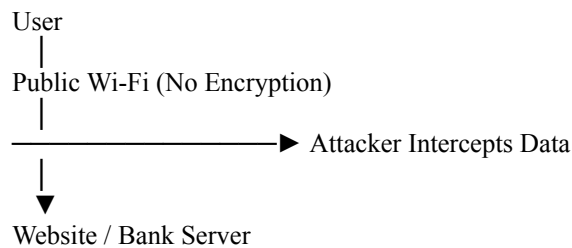
4. Identity Theft

Stolen personal information can be used to impersonate the user or commit financial fraud.

5. Session Hijacking

Attackers can steal session cookies and gain unauthorized access to the user's active online accounts.

Risk Diagram



Result:

- Password Stolen
- Banking Details Exposed
- Personal Data Leaked

Example

A customer logs into an online banking website using free airport Wi-Fi.

The attacker captures:

- Username
- Password
- Account details

The attacker later logs into the customer's bank account and performs unauthorized transactions.

B. Recommend a Secure Communication Method and Justify How It Protects User Data

Recommended Method: Virtual Private Network (VPN) with HTTPS (TLS/SSL)

A **Virtual Private Network (VPN)** creates an encrypted tunnel between the user's device and a secure VPN server. In addition, **HTTPS** uses **TLS/SSL encryption** to secure communication between the browser and the website.

Working Process

Step 1

The user connects to the public Wi-Fi.

↓

Step 2

The user starts a VPN connection.

↓

Step 3

The VPN encrypts all internet traffic before it leaves the device.

↓

Step 4

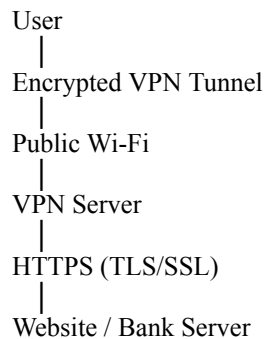
The encrypted data travels safely through the public Wi-Fi network.

↓

Step 5

The VPN server forwards the request securely to the destination website using **HTTPS (TLS/SSL)**.

Secure Communication Diagram



Attacker Sees:
Encrypted Data Only

Justification

1. Ensures Confidentiality

VPN and HTTPS encrypt all transmitted data, making it unreadable to attackers.

2. Protects Against Eavesdropping

Even if attackers intercept network traffic, they cannot understand the encrypted information.

3. Prevents Man-in-the-Middle Attacks

TLS/SSL verifies the identity of the website using digital certificates, reducing the risk of fake websites and intercepted communication.

4. Secures Sensitive Information

Passwords, banking details, emails, and personal data remain protected during transmission.

5. Enhances User Privacy

A VPN hides the user's IP address and encrypts internet traffic, improving privacy on public networks.

Advantages

- Encrypts all internet traffic.
 - Protects passwords and personal information.
 - Prevents eavesdropping.
 - Reduces Man-in-the-Middle attacks.
 - Secures online banking and shopping.
 - Improves privacy on public Wi-Fi.
 - Protects confidential business communications.
-

Applications

- Online banking
 - E-commerce websites
 - Email services
 - Corporate remote access
 - Cloud services
 - Mobile banking apps
 - Public Wi-Fi networks
 - Government and enterprise communication
-

Conclusion

Using an **unencrypted public Wi-Fi** network exposes users to risks such as **data interception, password theft, identity theft, session hijacking, and Man-in-the-Middle attacks**. A VPN combined with **HTTPS (TLS/SSL)** provides strong encryption, authenticates communication, and protects sensitive information from unauthorized access. Therefore, it is the recommended solution for secure communication over public Wi-Fi.

5. Data Integrity in Cloud Storage

An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

- A. Explain how hashing can be used to verify data integrity.
B. Suggest an additional mechanism to enhance trust and justify your answer.

ANSWER:

Scenario

A company named **XYZ Solutions** stores important files such as customer records, financial reports, and project documents on a **cloud server**. Since these files are stored on a third-party cloud service, the company wants to ensure that the data remains **unchanged** and has not been modified by attackers, software errors, or unauthorized users.

A. Explain how Hashing can be used to Verify Data Integrity

A **Hash Function** (such as **SHA-256**) generates a fixed-length value called a **hash** or **message digest** from the original data. Even a tiny change in the file produces a completely different hash value.

Working Process

Step 1: Generate Hash

Before uploading the file to the cloud, the organization generates a hash value using SHA-256.

↓

Step 2: Store File

The file is uploaded to the cloud, while the original hash value is stored securely.

↓

Step 3: Download File

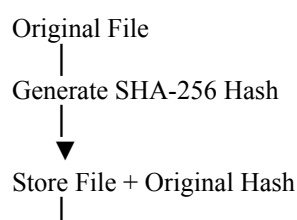
Whenever the file is downloaded, a new hash value is generated.

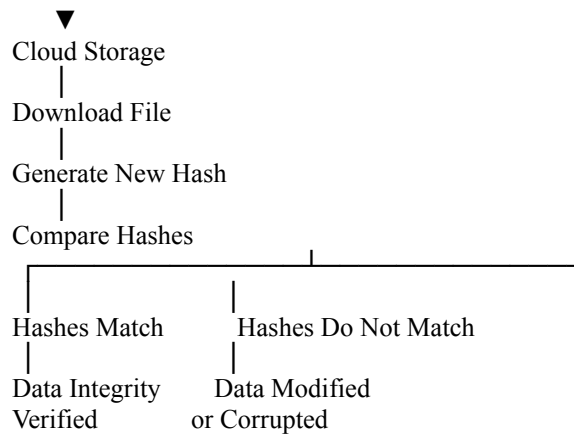
↓

Step 4: Compare Hash Values

- If both hash values are identical → The file has not been modified.
- If the hash values are different → The file has been altered or corrupted.

Hash Verification Diagram





Example

A company uploads a financial report.

Original File

Annual_Report.pdf

Generated Hash

A1B2C3D4E5F6...

Later, the company downloads the file.

- New Hash = **A1B2C3D4E5F6...** → File is unchanged.
- If New Hash = **X9Y8Z7P6...** → File has been altered.

Thus, hashing confirms whether the stored data is intact.

B. Suggest an Additional Mechanism to Enhance Trust and Justify Your Answer

Recommended Mechanism: Digital Signature

A **Digital Signature** enhances trust by proving both the **authenticity** of the file and its **integrity**.

Working Process

Step 1

The organization generates a hash of the file.



Step 2

The hash is encrypted using the organization's **private key**, creating a **digital signature**.



Step 3

The file and digital signature are uploaded to the cloud.

↓

Step 4

When the file is downloaded, the receiver:

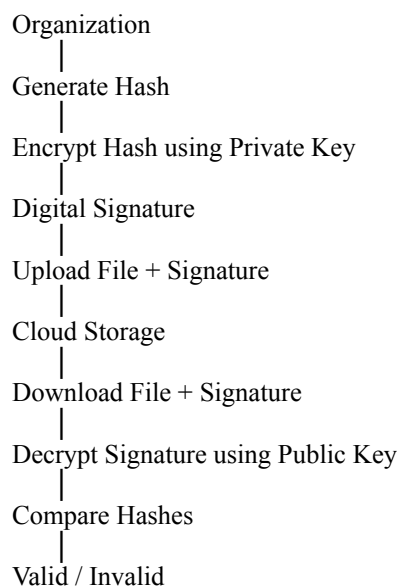
- Generates a new hash of the file.
- Uses the organization's **public key** to decrypt the digital signature.
- Compares both hash values.

↓

Step 5

- If the hashes match → The file is authentic and unchanged.
- If they differ → The file has been modified or is not from the claimed sender.

Digital Signature Verification Diagram



Justification

1. Ensures Data Integrity

Hash comparison immediately detects any modification to the stored file.

2. Provides Authentication

The digital signature verifies that the file was created by the legitimate organization.

3. Prevents Tampering

If an attacker changes the file, the hash values will not match, and verification fails.

4. Provides Non-Repudiation

Since only the organization possesses the private key, it cannot deny signing the file.

5. Builds Trust

Users can confidently verify that the downloaded file is genuine and has not been altered.

Advantages

- Detects unauthorized modifications.
 - Ensures data integrity.
 - Authenticates the file source.
 - Prevents data tampering.
 - Provides non-repudiation.
 - Increases trust in cloud storage.
 - Supports secure file sharing.
-

Applications

- Cloud storage services
 - Financial record management
 - Healthcare data storage
 - Government document repositories
 - Software updates
 - Digital certificates
 - Backup and disaster recovery systems
 - Enterprise document management
-

Conclusion

Hashing is an effective technique for verifying **data integrity** by generating a unique hash value for each file and comparing it during retrieval. To further enhance trust, **Digital Signatures** should be used, as they provide **authentication**, **integrity**, and **non-repudiation**. Together, hashing and digital signatures ensure that cloud-stored data remains secure, authentic, and unaltered.

RUBRICS FOR CALCULATION

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand